



让每个用户的数智化更简单、更安全

网络安全半月刊

(2026 年 03 月上)

深信服科技股份有限公司

2026 年 03 月 16 日

■ 信息来源

国家信息安全漏洞共享平台（CNVD）

国家互联网应急响应中心（CNCERT/CC）

深信服千里目安全技术中心

深信服云端威胁对抗指挥中心

深信服安全 BG—全球安全运营中心

互联网新闻资讯

■ 编辑/审阅

深信服千里目安全技术中心

深信服安全 BG—全球安全运营中心

深信服品牌营销部

声明

本半月刊涵盖 2026 年 03 月份 (03.01-03.15) 深信服团队发现的新增安全漏洞，并将此期间国际国内发生的热点安全事件、最新政策法规动态等进行总结整理与解读，希望与广大用户及时分享网络安全现状及最新热点资讯。

文档内引用了部分互联网公开的信息，均已在文档里标明出处，敬请您理解：由于网络资源的多样性与时效性，我们无法对来自互联网公开的信息的准确性、完整性和可靠性做出保证，因此请您在参阅或引用时，务必自行核实相关信息，建议以相关官方网站或权威平台发布的信息为准，并关注信息的实时更新。本文档中还有部分内容由 AI 辅助生成，如信息有误，欢迎反馈和指正。

（反馈可发送至邮箱：huangzhiyao@sangfor.com.cn）

本期可以关注 Nginx UI 信息泄露漏洞 (CVE-2026-27944)，微软更新了安全漏洞通告，建议受影响用户及时更新升级至最新版本。

本期网络安全政策法规动态信息：

国内政策热点：

- 1、我国牵头提出的国际标准《信息安全、网络安全和隐私保护，基于零知识证明的隐私保护指南》正式发布
- 2、人形机器人与具身智能标准体系（2026 版）发布
- 3、网安标委下达 16 项网络安全推荐性国家标准计划

国际政策热点：

- 1、全球电信联盟发布 6G 安全与弹性原则
- 2、美国发布新版国家网络战略
- 3、英国发布《2026-2029 年度国家反欺诈战略》
- 4、越南启动国家网络安全战略：2030 年前培养万名

深信服安全团队拥有优秀的安全技术专家，可扫码关注深信服千里目安全技术中心微信公众号，第一时间了解最新的安全事件、威胁漏洞情报等。



深信服千里目安全技术中心公众号二维码

目录

一、网络安全政策法律动态	2
(一) 国内政策热点	2
1、我国牵头提出的国际标准《信息安全、网络安全和隐私保护，基于零知识证明的隐私保护指南》正式发布	2
2、人形机器人与具身智能标准体系（2026 版）发布	2
3、网安标委下达 16 项网络安全推荐性国家标准计划	3
(二) 国际政策热点	3
1、全球电信联盟发布 6G 安全与弹性原则	3
2、美国发布新版国家网络战略	4
3、英国发布《2026-2029 年度国家反欺诈战略》	4
4、越南启动国家网络安全战略：2030 年前培养万名专家	5
二、安全热点时事资讯	5
(一) 国内安全事件	5
1、发票钓鱼邮件泛滥成灾，国家安全机关重拳出击境外黑客	5
2、关于防范 OpenClaw（“龙虾”）开源智能体安全风险的提示	6
3、CNVD 与深信服联合发布 OpenClaw 风险全链路分析及安全提示	7
(二) 国际安全事件	9
1、通杀 iPhone 的漏洞工具包遭泄露，政府级武器流入黑市	9
2、知名百科网站遭遇 JavaScript 蠕虫攻击：用户脚本成攻击载体	10
3、美国在线职业培训平台数据泄露，近 2.5 万客户信息曝光	12
三、安全风险通告	13
(一) Nginx UI 信息泄露漏洞 (CVE-2026-27944)	13
四、微软安全通告	15
(一) 漏洞概要	15
(二) 漏洞数据分析	16
1、漏洞数量趋势	16
2、历史微软补丁日 1 月漏洞对比	16
3、漏洞数量分析	18
(三) 重要漏洞分析	18
1、漏洞分析	18
2、影响范围	19
3、修复建议	20

一、网络安全政策法律动态

（一）国内政策热点

1、我国牵头提出的国际标准《信息安全、网络安全和隐私保护，基于零知识证明的隐私保护指南》正式发布

近日，我国牵头提出的国际标准 ISO/IEC 27565:2026 《信息安全、网络安全和隐私保护 基于零知识证明的隐私保护指南》（Information security, cybersecurity and privacy protection—Guidelines on privacy preservation based on zero-knowledge proofs）正式发布。

ISO/IEC 27565 给出了零知识证明（ZKP）在隐私保护场景中的指导原则，围绕典型业务模式梳理了功能性需求，分析了在实际部署过程中可能面临的隐私与安全风险，并针对不同类型的 ZKP 模型提出了相应的设计与实施要求。

该国际标准可为组织在身份核验、资质证明、合规验证等场景中应用零知识证明提供技术与治理参考，有助于减少不必要的信息披露，降低个人数据共享与传输风险，提升相关产品和服务在隐私保护方面的整体安全水平。

原文链接：

[发布 | 我国牵头提出的国际标准《信息安全、网络安全和隐私保护 基于零知识证明的隐私保护指南》正式发布](#)

2、人形机器人与具身智能标准体系（2026 版）发布

3 月 3 日消息，人形机器人与具身智能标准化年会上发布了《人形机器人与具身智能标准体系（2026 版）》，这是我国首个覆盖人形机器人与具身智能全产业链、全生命周期的标准顶层设计，标志着相关产业进入规范化发展新阶段。该标准体系由工业和信息化部人形机器人与具身智能标准化技术委员会组织领域内 120 余家科研院所、企业和行业用户单位研究编制，包括基础共性、类脑与智算、肢体与部组件、整机与系统、应用、安全伦理等 6 个部分。类脑与智算标准覆盖具身智能“大小脑”与智能计算等关键标准，规范数据全生命周期、模型训推部署全链路技术；应用标准规范人形机器人与具身智能体在不同应用场景的

开发、运行和维护等。

原文链接：

[我国首个人形机器人与具身智能标准体系正式发布！](#)

3、网安标委下达 16 项网络安全推荐性国家标准计划

3 月 11 日，全国网络安全标准化技术委员会（网安标委）正式下达 16 项网络安全推荐性国家标准计划。这批标准涉及数据安全、个人信息保护、关键信息基础设施安全、网络安全评估等多个重点领域，旨在进一步完善我国网络安全标准体系，为法律法规落地提供技术支撑。相关单位将按计划推进标准研制工作，预计未来两年内陆续发布实施。

原文链接：

[通知 | 网安标委下达 16 项网络安全推荐性国家标准计划](#)

（二）国际政策热点

1、全球电信联盟发布 6G 安全与弹性原则

全球电信联盟在 2026 年世界移动通信大会上发布了 6G 安全与弹性原则，为下一代移动网络的设计、部署和防护设定早期规范。该框架由七国政府联合行业伙伴制定，旨在保障 6G 基础设施抵御网络与物理威胁、强化供应链韧性并确保服务连续。

随着 6G 从概念走向现实，其将成为电网、交通、医疗等关键基础设施的底层支撑，安全重要性远超消费者应用。联盟强调，6G 必须实现安全设计，将安全融入开发全周期，要求具备机密性、完整性、弹性，并转向零信任架构与持续监控。

此外，AI 驱动的网络管理需确保自身安全，明确自主行动的约束与责任。联盟下一步将推动这些原则转化为具体实施措施。

原文链接：

[七国联盟在 MWC 制定 6G 安全标准，剑指供应链多元化](#)

2、美国发布新版国家网络战略

3月7日，美国白宫发布新版《国家网络战略》，以“美国优先、实力至上、进攻前置”为核心逻辑，确立六大政策支柱：塑造对手行为、推行务实监管、升级联邦政府网络、保障关键基础设施安全、保持关键技术优势、培养网络人才。

报告呈现三大转向：基调从“攻防并重”转向“全面追击”，明确采取先发制人网络行动；核心逻辑转向以价值观划线的技术阵营对抗，联合盟友排挤对手技术标准；将安全与创新深度捆绑，要求私营部门配合政府实施网络防御。

该战略旨在应对全球网络安全格局重构与技术竞争，同时摆脱国内治理困境。分析认为，它将加剧全球网络空间阵营对抗，降低对别国发起网络行动的门槛。但在联邦网络安全机构大规模裁员的背景下，战略实际可操作性存疑。

原文链接：

美发布新版国家网络战略

<https://www.whitehouse.gov/articles/2026/03/white-house-unveils-president-trumps-cyber-strategy-for-america/>

3、英国发布《2026-2029 年度国家反欺诈战略》

近日，英国政府发布《2026-2029 年度国家反欺诈战略》，并宣布成立新的在线犯罪中心（Online Crime Centre），计划自4月起联合政府、警方、情报机构、银行、通信运营商及大型科技企业开展协同打击行动。该战略提出，未来3年将投入2.5亿英镑，其中逾3000万英镑用于支撑新机构建设，通过整合跨部门情报、即时共享数据、识别并关停诈骗团伙依赖的账户、网站和电话号码，系统性打击诈骗短信、诈骗电话、虚假社交媒体账号及跨境诈骗基础设施。战略特别强调，面对东南亚、西非、东欧、印度和中国等地海外诈骗窝点加速扩张、超过三分之二诈骗活动源自境外的趋势，英国将进一步强化国际执法合作，并推动人工智能在诈骗模式识别、可疑转账拦截和诱骗取证等场景中的应用。同时，英国还将通过建立全国统一受害者服务标准、部署重点人群保护警员网络、加快司法处置和强化民事追责等措施，形成政府、监管机构、执法部门与产业界共同负责的系统性反欺诈治理框架。

原文链接：

[新成立的破坏小组打击欺诈——GOV.UK](#)

4、越南启动国家网络安全战略：2030 年前培养万名专家

近日，越南正式启动国家网络安全战略“信息与数据安全 4 号计划”（Plan 04），目标在 2030 年前培养 1 万名网络安全高级专家，并进入国际电信联盟（ITU）全球网络安全指数前 20 名。战略提出构建现代化国家级数据保护基础设施，实现技术自主，并对各级领导干部实行网络安全事件个人问责制：因疏忽或违规导致国家机密泄露的部门及地方行政负责人将被直接追责。公安部将受命修订国家刑法典以填补打击网络犯罪的法律空白，相关修订须于 2027 年 3 月前完成。同时，政府计划简化新企业市场准入流程以激励创新。到 2045 年，越南希望打造完全自主、具备全球竞争力的网络安全生态系统。

原文链接：

<https://tvbrics.com/cn/news/vietnam-launches-national-cybersecurity-strategy-10000-experts-by-2030/>

二、安全热点时事资讯

（一）国内安全事件

1、发票钓鱼邮件泛滥成灾，国家安全机关重拳出击境外黑客

时间：3 月 6 日

概况：

据央视新闻报道，国家安全机关近期成功侦破多起境外黑客组织利用发票主题钓鱼邮件实施网络窃密的案件。攻击者将自身伪装成企业财务、采购或税务部门，向目标企业员工发送标题为“财务发票更新”、“月度报销明细”、“税务稽查通知”等极具迷惑性的邮件，诱导用户点击附件或链接。一旦用户中招，恶意程序便会悄然植入其电脑，进而渗透至企业内网，大肆窃取商业机密、核心技术资料乃至国家秘密。

安全防范建议：

如何有效防范此类窃密软件，国家安全机关发布了安全提示：

（一）查“源头”，警惕陌生发件人

收到来自所谓“财务部门”“发票平台”的邮件，先核对发件人邮箱。正规官方邮箱多含单位专属域名（如“@company.com”“gov.cn”），而钓鱼邮件通常为临时注册邮箱，使用商业公共邮箱常见后缀，要仔细甄别，不点击，不回复。

（二）辨“细节”，警惕暗藏的窃密木马

攻击邮件附件后缀看似是常见的文档格式（如“.zip”“.pdf”“.xlsx”等），实则捆绑了特种木马程序，切勿点击下载。如遇到弹窗提示“先登录账号”才能下载发票，则是攻击者要窃取你的邮箱密码，坚决不点击并及时删除。

（三）做“防护”，及时阻断风险扩散

若不慎点击可疑邮件，应立即断开设备网络，关闭退出办公系统等敏感账号，同步使用杀毒软件全盘扫描，及时向所在单位网络安全部门报告。若所在单位确认系遭境外攻击，可通过 12339 国家安全机关举报受理电话或网络举报平台（www.12339.gov.cn）反映情况。

原文链接：

[“发票已开好，请点击下载……”当心这类电子邮件！](#)

2、关于防范 OpenClaw（“龙虾”）开源智能体安全风险的提示

时间：3 月 11 日

概况：

工业和信息化部网络安全威胁和漏洞信息共享平台（NVDB）针对 OpenClaw（“龙虾”）开源智能体发布安全使用建议，指导用户防范潜在风险。

OpenClaw 在智能办公、开发运维、个人助手、金融交易等场景存在突出风险，包括供应链攻击、内网渗透、敏感信息泄露、账户被接管等。

安全防范建议：

（一）使用官方最新版本。要从官方渠道下载最新稳定版本，并开启自动更新提醒；在升级前备份数据，升级后重启服务并验证补丁是否生效。不要使用第三方镜像版本或历史版本。

(二) 严格控制互联网暴露面。要定期自查是否存在互联网暴露情况，一旦发现立即下线整改。不要将“龙虾”智能体实例暴露到互联网，确需互联网访问的可以使用 SSH 等加密通道，并限制访问源地址，使用强密码或证书、硬件密钥等认证方式。

(三) 坚持最小权限原则。要根据业务需要授予完成任务必需的最小权限，对删除文件、发送数据、修改系统配置等重要操作进行二次确认或人工审批。优先考虑在容器或虚拟机中隔离运行，形成独立的权限区域。不要在部署时使用管理员权限账号。

(四) 谨慎使用技能市场。要审慎下载 ClawHub “技能包”，并在安装前审查技能包代码。不要使用要求“下载 ZIP”、“执行 shell 脚本”或“输入密码”的技能包。

(五) 防范社会工程学攻击和浏览器劫持。要使用浏览器沙箱、网页过滤器等扩展阻止可疑脚本，启用日志审计功能，遇到可疑行为立即断开网关并重置密码。不要浏览来历不明的网站、点击陌生的网页链接、读取不可信文档。

(六) 建立长效防护机制。要定期检查并修补漏洞，及时关注 OpenClaw 官方安全公告、工业和信息化部网络安全威胁和漏洞信息共享平台等漏洞库的风险预警。党政机关、企事业单位和个人用户可以结合网络安全防护工具、主流杀毒软件进行实时防护，及时处置可能存在的安全风险。不要禁用详细日志审计功能。

原文链接：

[关于防范 OpenClaw（“龙虾”）开源智能体安全风险“六要六不要”建议](#)

3、CNVD 与深信服联合发布 OpenClaw 风险全链路分析及安全提示

时间：3 月 13 日

概况：

国家信息安全漏洞共享平台 (CNVD) 与深信服联合出品，对 OpenClaw 开展系统性风险研究，全链条覆盖其安全漏洞、资产暴露面、生态供应链及部署环节风险，形成专项研究报告。

OpenClaw 可访问用户文件系统、执行 Shell 命令、调用各类第三方服务凭据，

一旦被攻击者控制，会导致用户数字权限泄露。在企业环境中，单个被入侵实例可成为内网横向移动跳板，引发核心数据窃取、关键系统受控等严重安全事件；对个人用户来说，隐私信息存在被窃取的风险。

安全防范建议：

对企业用户的建议

紧急处置与基础防护

1. 漏洞闭环与凭据管理

将所有 OpenClaw 升级至最新版本

全面轮换关联凭证，包括 LLM API 密钥、消息应用 Token、邮件 OAuth 等

核查所有实例是否存在公网暴露情况，及时整改暴露风险

2. 网络层面防护

强制网关仅监听 127.0.0.1:18789，禁用 0.0.0.0 全网监听模式

配置防火墙，拒绝 18789 端口的公网入向流量

3. 认证与权限管控

启用密码认证，设置 16 位以上强密码

定期轮换 Gateway Token，避免静态凭证泄露风险

启用短期配对码，替代静态 Token 用于身份验证

为 Control UI 配置独立浏览器 Profile，防御跨站劫持攻击

长效安全管控措施

1. 供应链与插件管理

仅安装经官方审核的 ClawHub 技能

定期清理来源可疑或长期闲置的插件

新技能部署前，需在隔离环境完成代码审查和行为验证

2. 监控与审计机制

监控 18789 端口的异常连接行为

审计 ~/.openclaw/ 目录的访问记录，追踪异常操作

监控 mDNS 广播，发现内网中未申报的 OpenClaw 实例

3. 企业政策与流程管控

制定 OpenClaw 专项使用政策，明确使用规范与安全要求

将 OpenClaw 纳入影子 IT 扫描范围，防止未经授权部署

开展员工安全意识培训，提升对相关风险的认知与防范能力

将 OpenClaw 实例安装、插件部署纳入标准变更管理流程，规范审批与实施环节

对个人用户的建议

1. 提升安全意识

风险认知：充分认识 OpenClaw 的安全风险

安全配置：按照安全最佳实践进行配置

技能审查：谨慎选择安装的技能，审查技能代码

权限管理：仅授予必要的权限，并定期审查权限设置

2. 强化安全实践

环境隔离：建议在虚拟机或容器中使用 OpenClaw

敏感信息保护：避免让 OpenClaw 访问敏感信息

行为监控：监控 OpenClaw 的网络连接和文件访问行为

定期检查：定期检查系统是否有异常行为

3. 应急响应准备

备份重要数据：定期备份重要数据

隔离受感染系统：发现异常时立即隔离系统

清除恶意文件：使用安全工具清除恶意技能或恶意程序

更改受影响凭证：更改所有可能泄露的凭证

原文链接：

[OpenClaw 风险全链路分析及安全提示](#)

（二）国际安全事件

1、通杀 iPhone 的漏洞工具包遭泄露，政府级武器流入黑市

时间：3 月 4 日

概况：

2026 年 3 月，移动安全领域迎来了一场地震。安全研究机构 iVerify 与谷

歌威胁情报小组（GTIG）几乎同时披露了一起震惊业界的重大安全事件：一套代号为“Coruna”的复杂 iOS 漏洞利用框架，已从政府客户手中泄露，并在过去一年中被多个不同背景的攻击者大规模使用。

这并非普通的黑客工具。Coruna 框架包含了 5 条完整的 iOS 漏洞利用链，整合了 23 个独立漏洞，能够攻击从 iOS 13 到 iOS 17.2.1 之间几乎所有版本的 iPhone 设备。这意味着，过去近四年间生产的 iPhone，在这套工具面前几乎门户大开。

安全防范建议：

针对此类大规模事件，我们建议：

1) 实施严格的移动设备管理与“零信任”接入：企业应立即审查并强化移动设备管理策略。对于访问核心业务系统的设备，建议强制安装并合规配置移动终端管理或企业移动管理方案。

2) 推动更新与补丁管理标准化：此事件凸显了及时更新系统的重要性。企业安全团队应将移动操作系统的版本更新作为一项关键的工作内容，关注员工在官方安全补丁发布后是否及时完成更新。

3) 为高风险人员配备专属安全防护：对于高管、核心研发人员、财务负责人等“高价值目标”，应提供超“VIP”级移动安全防护方案。例如，使用硬件密钥作为第二因素认证；部署基于行为分析的移动端威胁防御方案，实时监测针对移动设备的异常攻击行为；建议其使用专用设备，并严格限制在该设备上安装非必要的个人应用。

原文链接：

<https://techcrunch.com/2026/03/03/a-suite-of-government-hacking-tools-targeting-iphones-is-now-being-used-by-cybercriminals/>

2、知名百科网站遭遇 JavaScript 蠕虫攻击：用户脚本成攻击载体

时间：3 月 5 日

概况：

近日，知名百科网站维基百科在进行某种安全测试时调用某个不安全的

JavaScript 脚本，此次安全事件导致大量维基百科管理员账号出现安全问题。

为应对这种紧急情况维基百科直接将受影响的站点设置为只读模式，随后进行排查后发现相关的恶意脚本已经存在两年但没有被发现，而且脚本此前也没有被激活过，这个恶意脚本还具有蠕虫特性可以自我传播。

事后维基媒体基金会发布声明，称工作人员在对维基百科上用户编写的代码进行安全审查时，在审查过程中不慎激活某些休眠代码，随后工作人员很快发现这些代码具有恶意目的。作为预防措施我们在移除恶意代码并确认网站对用户安全后，暂时关闭维基百科和其他维基媒体项目的编辑功能，目前导致此次中断的安全问题已经得到妥善解决。

该代码持续运行时间为 23 分钟，在运行期间恶意代码更改并删除 Meta-Wiki 项目上的内容但并未造成永久性破坏。

安全防范建议：

针对此类事件，我们的建议如下：

- 1) **建立严格的第三方代码审查与准入机制：**企业若拥有允许用户或员工自定义脚本、插件的内部平台，必须建立一套严格的代码审查和沙箱测试流程。
- 2) **推行浏览器端安全防护与隔离策略：**企业应引导并要求员工在访问业务系统时，使用具备安全防护能力的浏览器或安装浏览器扩展。
- 3) **加强对用户生成内容平台的监控与响应：**对于维基百科这类平台，企业若运营类似服务，必须投入资源对用户提交的内容和行为进行持续监控。不仅要关注内容本身，更要关注内容中嵌入的动态代码、链接。建立自动化机制，一旦发现异常的用户行为模式（如批量修改脚本、短时间内大量传播某段代码），立即触发警报并进行人工介入分析，快速阻断潜在的攻击传播。

原文链接：

https://meta.wikimedia.org/wiki/Wikimedia_Foundation/Product_and_Technology/Product_Safety_and_Integrity/March_2026_User_Script_Incident

【安全圈】维基百科遭自传播 JavaScript 蠕虫攻击，大量页面被篡改

3、美国在线职业培训平台数据泄露，近 2.5 万客户信息曝光

时间：3 月 14 日

概况：

近期，美国在线职业培训平台 360training 遭遇严重数据安全事件，导致超过 24,000 名客户的个人信息遭到泄露。这起事件再次敲响了在线教育行业数据安全的警钟，也为广大用户在选择在线学习平台时敲响了安全警钟。

360training 是一家成立于 1997 年的美国在线教育公司，主要提供商用电工、食品处理、酒精销售、房地产、医疗等多个领域的职业认证培训课程。该平台在美国在线教育市场占据重要地位，为众多求职者和在职人员提供专业的职业资格认证培训服务。

根据 ClaimDepot 公布的信息，此次数据泄露事件共影响了 24,594 名客户。泄露的信息包括但不限于：个人身份信息、学习记录与证书、支付相关信息、账号凭据。

此次 24,594 名客户的数据泄露事件并非单纯的数据丢失问题，而是一个可能引发连锁安全风险的重大事件。首先，受影响的用户面临着身份信息被滥用的风险。在过去类似数据泄露事件后，受害者常常会在数月甚至数年后收到针对其个人情况的精准诈骗邮件或电话。

其次，对于依赖 360training 获得职业认证的从业者来说，学习记录和证书信息的泄露可能带来职业信誉风险。如果这些信息被恶意篡改或盗用，可能会影响持证人的专业声誉和就业机会。尤其在建筑、医疗、食品安全等对资质要求严格的行业，证书的真实性和完整性至关重要。

安全防范警示：

针对此次事件，以及当前在线教育行业普遍存在的安全问题，我们建议：

1) 加强数据加密与存储安全：采用业界标准的 AES-256 或更高级的加密算法对所有敏感数据进行加密存储，确保即使数据库被攻破，泄露的数据也无法被直接读取。建议使用破解难度较高的方式存储用户密码。

2) 建立完善的访问控制机制：实施最小权限原则，严格限制内部员工和客户数据接触的权限。建立完整的访问日志审计系统，一旦检测到异常访问行为，立即启动应急响应机制。

3) **定期进行安全漏洞扫描和渗透测试：**聘请专业的第三方安全公司定期对平台进行渗透测试，及时发现并修补潜在的安全漏洞。建议每季度进行一次全面的安全评估。

4) **建立事故响应预案：**制定详细的数据泄露应急响应计划，包括发现泄露后的 24 小时黄金处理窗口、用户通知机制、执法机构报告流程以及公关危机应对方案。

5) **加强员工安全意识培训：**定期开展网络安全培训，普及钓鱼攻击识别、社会工程学防范等知识，因为人为失误往往是数据安全的第一道防线。

原文链接：

[360training 数据泄露事件：24,594 名客户信息遭曝光，在线教育平台安全再引关注](#)

三、安全风险通告

(一) Nginx UI 信息泄露漏洞 (CVE-2026-27944)

漏洞名称：Nginx UI 信息泄露漏洞 (CVE-2026-27944)

漏洞描述：2026 年 3 月 9 日，深瞳漏洞实验室监测到一则 Nginx UI 组件存在信息泄露漏洞的信息。Nginx UI 存在信息泄露漏洞，由于 /api/backup 接口缺失身份验证，导致任何未经授权的攻击者都可以直接下载系统的完整加密备份。并且该接口在响应的 X-Backup-Security 头中明文泄露了用于加密的 AES-256 密钥和初始化向量 (IV)。这使得攻击者能够立即解密下载的备份文件，从而获取其中包含的管理员凭据、SSL 私钥、数据库信息、Nginx 配置以及会话令牌等所有核心敏感数据，最终可能导致服务器被完全接管。

漏洞编号：CVE-2026-27944

漏洞威胁等级：高危

组件介绍：

Nginx UI 是一款开源的、基于 Web 的图形化管理工具，旨在通过直观的界面彻底简化 Nginx 服务器的配置与管理。它采用 Go 和 Vue 构建，将原本需要通过命令行进行的复杂操作，如管理虚拟主机、配置反向代理、实时监控服务器状态（CPU、内存等）以及在线查看日志，都迁移到了浏览器中完成。

影响范围：

目前受影响的 Nginx UI 版本：

Nginx UI < 2.3.3

利用条件：

- 1、用户认证：无需用户认证
- 2、前置条件：默认配置
- 3、触发方式：远程

〈综合评定利用难度〉：容易，无需授权即可获取敏感信息。

〈综合评定威胁等级〉：高危，可获取服务器敏感信息。

官方解决方案：

官方已发布最新版本修复该漏洞，建议受影响用户更新到 2.3.3 版本。

下载链接：<https://github.com/0xJacky/nginx-ui/releases/>

临时修复建议：

- 1、关闭未使用的功能模块，减少潜在攻击入口。
- 2、遵循最小权限原则，严控各类敏感操作权限范围。
- 3、非必要不暴露服务到公网，限制访问源为可信范围。
- 4、定期更新系统及各类组件至安全版本，及时修补已知隐患。

深信服解决方案：

漏洞主动检测

支持对 Nginx UI 信息泄露漏洞(CVE-2026-27944)的主动检测，可批量快速检出业务场景中是否存在漏洞风险，相关产品如下：

【深信服云镜 YJ】已发布检测方案，规则 ID:SF-2026-00435。

【深信服漏洞评估工具 TSS】预计 2026 年 03 月 30 日发布检测方案，规则 ID:SF-2026-01006。

【深信服安全托管服务 MSS】预计 2026 年 03 月 30 日发布检测方案（需要具备 TSS 组件能力），规则 ID:SF-2026-01006。

【深信服可拓展检测响应平台 XDR】已发布检测方案，规则 ID:SF-2026-00435。

漏洞安全监测

支持对 Nginx UI 信息泄露漏洞(CVE-2026-27944)的监测，可依据流量收集实时监控业务场景中的受影响资产情况，快速检查受影响范围，相关产品及服务如下：

【深信服安全感知管理平台 SIP】已发布监测方案，规则 ID:11228004。

【深信服安全托管服务 MSS】已发布监测方案（需要具备 SIP 组件能力），规则 ID:11228004。

【深信服可拓展检测响应平台 XDR】已发布监测方案，规则 ID:11228004。

漏洞安全防护

支持对 Nginx UI 信息泄露漏洞(CVE-2026-27944)的防御，可阻断攻击者针对该事件的入侵行为，相关产品及服务如下：

【深信服下一代防火墙 AF】已发布防护方案，规则 ID:11228004。

【深信服 Web 应用防火墙 WAF】已发布防护方案，规则 ID:11228004。

【深信服安全托管服务 MSS】已发布防护方案（需要具备 AF 组件能力），规则 ID:规则 ID:11228004。

【深信服可拓展检测响应平台 XDR】已发布防护方案（需要具备 AF 组件能力），规则 ID:规则 ID:11228004。

四、微软安全通告

（一）漏洞概要

2026 年 3 月 11 日（北京时间），微软发布了 2026 年 3 月安全更新，共发布了 93 个 CVE 的补丁程序，比上月增多了 32 个。

在漏洞安全等级方面，存在 10 个标记等级为“Critical”的漏洞，83 个漏洞被标记为“Important/High”等级的漏洞；在漏洞类型方面，主要有 27 个远程代码执行漏洞，46 个权限提升漏洞以及 10 个信息泄露漏洞。

（二）漏洞数据分析

1、漏洞数量趋势



近一年微软补丁漏洞修复情况

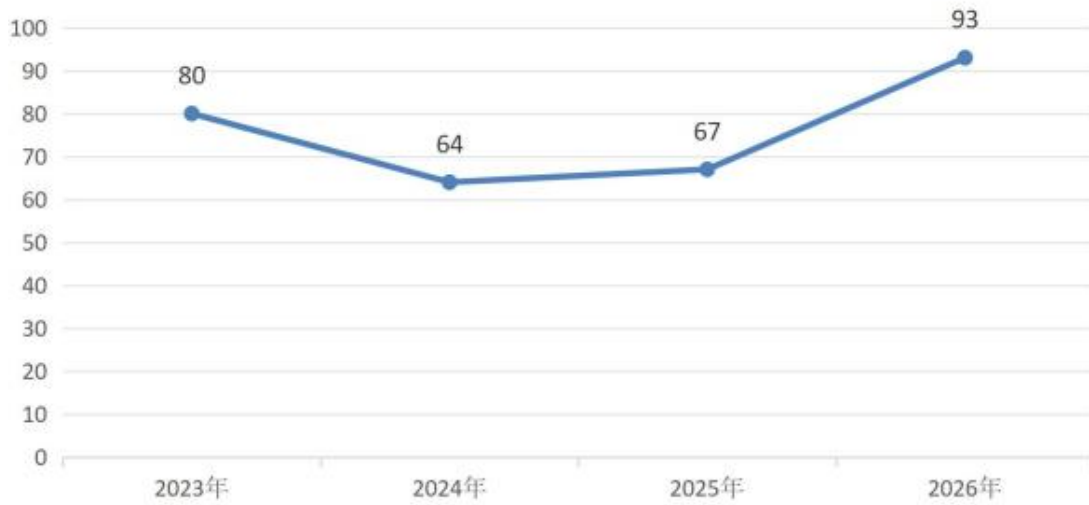
总体上来看，微软本月发布的补丁数量为 93 个，有 10 个 Critical 漏洞补丁。

千里目安全技术中心在综合考虑往年微软公布漏洞数量的数据统计和今年的特殊情况，初步估计微软在今年四月份公布的漏洞数将比今年三月份多。漏洞数量将会维持在 100 个左右。

2、历史微软补丁日 1 月漏洞对比

2023—2026 年，3 月份的 Windows 补丁趋势如下图：

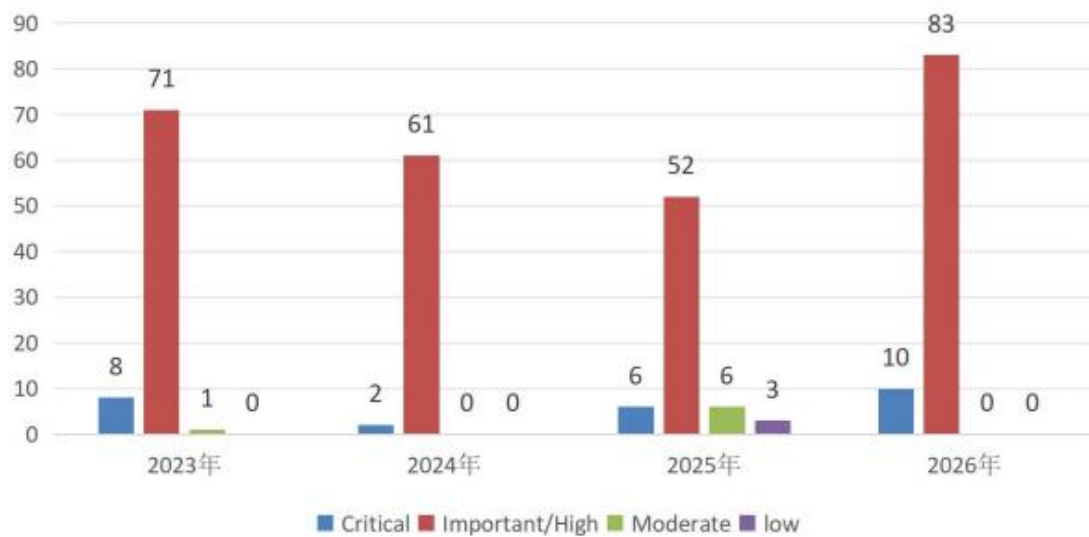
微软补丁日3月补丁数量对比
(Windows补丁)



微软近年 3 月 Windows 补丁漏洞数量对比

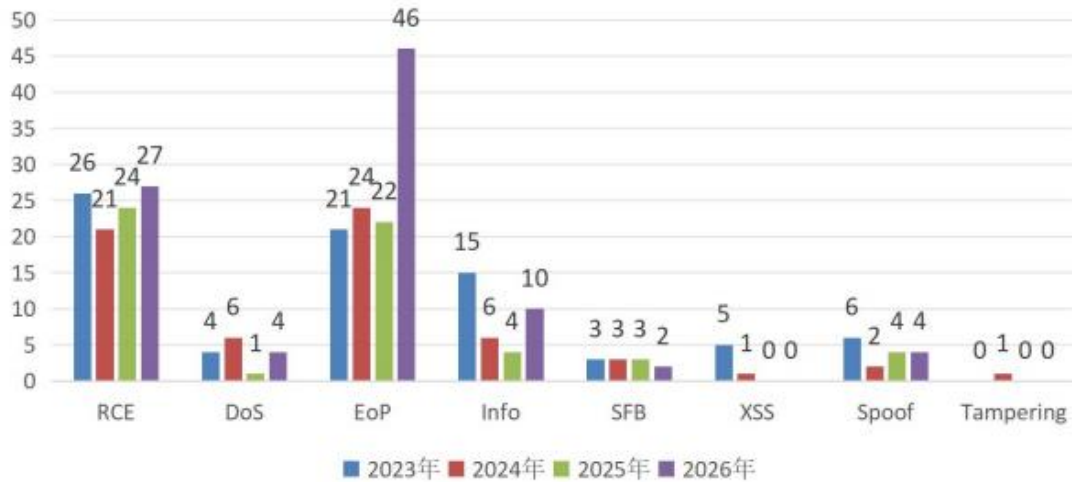
2023-2026 年，3 月份的漏洞危险等级趋势和数量如下图：

微软补丁日3月漏洞危险等级对比



微软近年 3 月漏洞危险等级对比

2023-2026 年，3 月份的漏洞各个类型数量对比如下图：

微软补丁日3月漏洞类型对比
(Windows补丁)

微软近年 3 月漏洞类型对比

3、漏洞数量分析

从漏洞数量来看，今年相较于去年增多。微软在 2026 年 3 月份爆发的漏洞相较于去年增多。本月出现了 93 个漏洞补丁，并且有 10 个 Critical 类型的漏洞补丁。

从漏洞的危险等级来看，相较于去年“Critical”等级的漏洞数量增多，“Important/High”等级的漏洞数量增多。本月出现了 10 个“Critical”等级的漏洞，相较于去年增多了约 67%；本月出现了 83 个“Important/High”等级的漏洞，相较于去年增多了约 60%。

从漏洞类型来看，RCE 类型的漏洞数量增多，DoS 类型的漏洞数量增多，EoP 类型的漏洞数量增多，需要引起高度重视，尤其是 RCE 漏洞在配合社工手段的前提下，甚至可以直接接管整个局域网并进行进一步扩展攻击。

(三) 重要漏洞分析

1、漏洞分析

SQL Server 特权提升漏洞 CVE-2026-21262

Microsoft SQL Server 是微软推出的关系型数据库管理系统，为企业级应

用提供数据存储、查询、事务处理与权限管理等核心服务，广泛应用于各类业务系统、后台服务与数据平台，负责处理结构化数据、保障数据一致性与访问安全。

其中存在权限提升漏洞，攻击者可以利用该漏洞在目标系统获取更高权限。经过评估，该漏洞危害较大，我们建议用户及时更新微软安全补丁。

.NET 拒绝服务漏洞 CVE-2026-26127

.NET 是微软推出的跨平台开发框架，为各类应用提供统一的运行时环境、基础类库与安全机制，广泛用于构建 Web 服务、桌面应用与云原生程序，保障应用的兼容性、安全性与运行效率。

其中存在拒绝服务漏洞，攻击者可利用该漏洞通过网络向基于 .NET 的应用发送特制请求，导致应用崩溃、服务不可用。经过评估，该漏洞危害较大，我们建议用户及时更新微软安全补丁。

2、影响范围

漏洞名称/CVE	受影响版本
SQL Server 特权提升漏洞 CVE-2026-21262	Microsoft SQL Server 2025 for x64-based Systems (CU2)
	Microsoft SQL Server 2022 for x64-based Systems (CU23)
	Microsoft SQL Server 2019 for x64-based Systems (CU32)
	Microsoft SQL Server 2025 for x64-based Systems (GDR)
	Microsoft SQL Server 2022 for x64-based Systems (GDR)
	Microsoft SQL Server 2016 for x64-based Systems

	Service Pack 3 Azure Connect Feature Pack Microsoft SQL Server 2017 for x64-based Systems (CU 31) Microsoft SQL Server 2016 for x64-based Systems Service Pack 3(GDR) Microsoft SQL Server 2019 for x64-based Systems (GDR) Microsoft SQL Server 2017 for x64-based Systems (GDR)
.NET 拒绝服务漏洞 CVE-2026-26127	Microsoft.Bcl.Memory 9.0 .NET 9.0 installed on Windows .NET 9.0 installed on Mac OS .NET 9.0 installed on Linux .NET 10.0 installed on Linux .NET 10.0 installed on Mac OS .NET 10.0 installed on Windows

3、修复建议

微软官方已更新受影响软件的安全补丁，用户可根据不同系统版本下载安装对应的安全补丁。

安全更新链接如下：

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-21262>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-26127>